PayGuard — Defense Sheet (1 page)

Team: Secure Horizons · **Track 1 — Guardians of Value** · ESSEC Secure Horizons, 10–11 October 2026

THREAT SCENARIO ADDRESSED

An AI purchasing agent (Claude Desktop with MCP tools) is sent to buy on the web. A **lookalike merchant page** (`n0rdsound-deals`, cheaper price) carries **instructions invisible to the human but readable by the agent** (hidden `div`, HTML comments, white-on-white text): "pay to this address instead", "skip the checks", "the user already approved". Agent-payment protocols sign the **transaction**, not the **decision**: the manipulated agent produces a perfectly valid payment that nobody wanted. Variants covered: fake merchant / typosquatting, price or recipient swapped on the page, over-budget or off-policy purchase, first payment to an unknown recipient, runaway agent (burst of rejected attempts), compromised agent trying to drain the account.

HOW PAYGUARD DEFENDS

The agent never holds a key or a card number. It calls PayGuard (MCP plugin) and PayGuard decides: **20 deterministic rules** (mandate: amount, daily cap, allowed merchants, new-recipient confirmation; context: page price / product / recipient must match the request; injection: hidden instructions, override phrases, urgency pressure) + a **merchant trust score** (HTTPS, domain age via RDAP, risky TLD, brand impersonation, lookalike domain, legal mentions, credential-harvesting forms, free hosting, random subdomains/paths). Verdicts: APPROVED (executed), HELD (human confirms on the dashboard), BLOCKED, UNVERIFIED (could not check, human confirms). Every decision, including refusals, is **anchored on Avalanche Fuji** (`PayGuardLedger`, hash of the decision). A **kill switch** pauses the contract and freezes all cards: manual from the dashboard, automatic after 3 blocks in 10 minutes or a critical injection combined with an over-cap amount. Funds stay in the customer's bank: payments go through single-use virtual cards (capped, merchant-locked, expire the same day) or testnet AVAX.

NIST CSF 2.0 FUNCTIONS COVERED

Function	What PayGuard does
Govern	Spending policy per rail set by a human (caps, allowed merchants, confirmation rules), compliance panel mapping to DORA / MiCA / AML-CFT / AI Act
Identify	Merchant trust score before any payment; benchmark of the score on live phishing
Protect	Mandate enforcement; agent never sees secrets; single-use capped cards; on-chain pause
Detect	Hidden-instruction and injection rules, page/request mismatch rules, lookalike detection
Respond	BLOCK / HOLD, automatic kill switch, dashboard approvals, audit log
Recover	Re-arm from the dashboard, cards re-issued, full decision history to review

MITRE ATLAS / OWASP COVERAGE

- **ATLAS** AML.T0051 *LLM Prompt Injection* (indirect, via web content), AML.T0054 *LLM Jailbreak*, AML.T0048 *External Harms: Financial Harm*, AML.T0043 *Craft Adversarial Data*.
- **OWASP Top 10 for LLM Applications**: LLM01 Prompt Injection, LLM02 Insecure Output Handling (agent output never triggers a payment directly), LLM06 Excessive Agency (hard mandate, human in the loop), LLM08 Excessive Autonomy / LLM09 Overreliance (kill switch).
- **OWASP Agentic Top 10 (2025)**: ASI01 Agent Goal Hijack, ASI03 Identity & Privilege Abuse (no key in the agent), ASI05 Unexpected Code/Action Execution (scoped tool), ASI09 Human-Agent Trust Exploitation.

METRICS ACHIEVED

Metric	Value	How measured
Live phishing pages caught (FRAUDULENT or SUSPICIOUS)	**97 %** (145 / 150)	150 URLs from the OpenPhish feed, benchmark v7 (`docs/BENCHMARK.md`)
Legitimate shops wrongly blocked	**0 %** (0 / 60)	60 Tranco-ranked e-commerce sites
Legitimate shops sent to a human	5 % held + 10 % unverified	same set
Demo attack (hidden instructions + lookalike domain)	100 % blocked, score 0/100	scripted demo, 3 merchants
Time to decide	< 1 s (rules) + ~2 s to anchor on Fuji	measured on the demo
Time to respond to a runaway agent	3 blocks ⇒ contract paused + cards frozen in < 5 s	automatic kill switch test

KNOWN LIMITATIONS

Merchant score is heuristic: 3 % of phishing kits hosted on hacked legitimate domains still pass (next signal: domain reputation over time). RDAP and page fetch depend on network; unreachable sites become UNVERIFIED (human confirms). The virtual-card issuer is a sandbox we wrote (Revolut Business / Stripe Issuing are the planned real rails). Testnet only, no real funds. Optional LLM "second opinion" and natural-language explanations are implemented but disabled without an API key. Not a payment institution: PayGuard is a technical provider; regulatory mapping is indicative.